

Here's a **final quick reference cheat sheet for Domain 2 (Security & Compliance, 30%)** for exam-ready review:

1. Shared Responsibility Model

- **AWS responsibility (Security of the cloud):**
 - Physical security of data centers
 - Hardware, software, networking
 - Managed services security
- **Customer responsibility (Security in the cloud):**
 - Customer data
 - IAM users/groups/roles/policies
 - OS patches, application security
 - Network traffic configuration

Exam tip: Questions often ask: *“Who is responsible for X?”*

2. IAM (Identity & Access Management)

- **Users:** Individual credentials
 - **Groups:** Collection of users with shared permissions
 - **Roles:** Temporary credentials for services/users
 - **Policies:** JSON-based permission rules
 - **MFA:** Multi-Factor Authentication
 - **Principle:** Least privilege
-

3. AWS Cognito

- User authentication & management
 - Sign-in/sign-up for mobile & web apps
 - Integration with social identity providers
-

4. AWS Organizations

- Account management & central governance
 - Consolidated billing
 - Service control policies (SCPs)
-

5. Security, Identity & Compliance Services

Service	Purpose
KMS	Create/manage encryption keys, envelope encryption
Secrets Manager	Store DB/API keys securely
Shield	DDoS protection (Standard & Advanced)
WAF	Protect web apps from exploits
Macie	Discover sensitive data in S3

6. Logging & Monitoring

- **CloudTrail:** Logs API calls & tracks activity
 - **Config:** Tracks resource compliance & changes
 - **CloudWatch:** Metrics, logs, alarms
-

7. Compliance Programs

- **HIPAA:** Health data
 - **SOC 1/2/3:** System controls
 - **PCI DSS:** Payment card data
 - **ISO 27001/27017/27018:** Security & cloud standards
 - **FedRAMP:** US government
 - **GDPR:** EU privacy
-

8. Data Protection & Encryption

- **S3:** SSE-S3 / SSE-KMS / SSE-C
 - **EBS:** Encrypt volumes & snapshots
 - **RDS:** Encryption at rest & in transit
-

9. Network Security

- **VPC Security:** Security Groups (stateful), Network ACLs (stateless)
 - **VPN & Direct Connect:** Secure on-premises connection
-

10. Security Best Practices

- Enable MFA for all users
- Use IAM roles, not long-term credentials
- Rotate keys/passwords regularly
- Apply least privilege principle

- Enable CloudTrail in all regions
 - Use AWS Config for compliance
-

11. Exam Quick Reference Table

Tool	Function
IAM	User & permission management
KMS	Encryption key management
CloudTrail	API call logging
CloudWatch	Monitoring & alarms
Config	Resource compliance
Shield	DDoS protection
WAF	Web application firewall
Macie	Sensitive data detection
Secrets Manager	Secrets storage

[📖 Domain 2: Security and Compliance \(30%\) – Complete Topic List](#)

1. Shared Responsibility Model

- AWS responsibility (“Security **of** the cloud”):
 - Physical security of data centers
 - Hardware, software, networking
 - Managed services security
 - Customer responsibility (“Security **in** the cloud”):
 - Customer data
 - IAM users, groups, roles, policies
 - OS patches, application security
 - Network traffic configuration
-

2. Identity and Access Management (IAM)

- IAM Users: Individual identities with credentials
 - IAM Groups: Collection of users with common permissions
 - IAM Roles: Temporary credentials for services or users
 - IAM Policies: JSON-based permission rules
 - Multi-Factor Authentication (MFA)
 - Principle of least privilege
-

3. AWS Cognito

- User authentication and management
 - Sign-in/sign-up for mobile & web apps
 - Integration with social identity providers
-

4. AWS Organizations

- Account management & central governance
 - Consolidated billing
 - Service control policies (SCPs)
-

5. Security, Identity, and Compliance Services

- **AWS KMS (Key Management Service):**
 - Create/manage encryption keys
 - Envelope encryption
 - **AWS Secrets Manager:**
 - Store secrets like DB passwords or API keys securely
 - **AWS Shield:**
 - DDoS protection
 - Standard (free) & Advanced (paid)
 - **AWS WAF (Web Application Firewall):**
 - Protect web applications from common exploits
 - **AWS Macie:**
 - Data security & privacy
 - Discover sensitive data in S3
-

6. Logging and Monitoring

- **AWS CloudTrail:**
 - Logs all API calls
 - Tracks user activity & changes
 - **AWS Config:**
 - Tracks resource compliance
 - Monitors changes & configurations
 - **Amazon CloudWatch:**
 - Monitors metrics, logs, and alarms
-

7. Compliance Programs

- AWS compliance frameworks:
 - **HIPAA:** Health data
 - **SOC 1/2/3:** System controls reports
 - **PCI DSS:** Payment card security
 - **ISO 27001/27017/27018:** Security & cloud-specific standards
 - **FedRAMP:** US government cloud security
 - **GDPR:** EU data privacy
-

8. Data Protection & Encryption

- **S3 Encryption:**
 - SSE-S3 (server-side encryption with S3 managed keys)
 - SSE-KMS (server-side encryption with KMS managed keys)
 - SSE-C (customer-provided keys)
 - **EBS Encryption:**
 - Encrypt EBS volumes & snapshots
 - **RDS Encryption:**
 - Encryption at rest & in transit
-

9. Network Security

- **VPC Security:**
 - Security Groups (virtual firewall for EC2)
 - Network ACLs (stateless firewall at subnet level)
 - **VPN & Direct Connect:** Secure connection from on-premises to AWS
-

10. Security Best Practices

- Enable MFA for all users
 - Use IAM roles instead of long-term credentials
 - Rotate keys and passwords regularly
 - Apply least privilege principle
 - Enable CloudTrail in all regions
 - Use AWS Config for compliance
-

11. AWS Security Tools Quick Reference

Tool	Purpose
IAM	User & permission management

Tool	Purpose
KMS	Encryption key management
CloudTrail	API call logging
CloudWatch	Monitoring & alarms
AWS Config	Resource compliance
Shield	DDoS protection
WAF	Web application firewall
Macie	Sensitive data detection
Secrets Manager	Secrets storage

☒ **Exam Tip:** Almost all Domain 2 questions are **about matching services to security functions** or **who is responsible under Shared Responsibility**. Memorize **IAM, CloudTrail, Config, KMS, Shield, WAF, Macie**.